

Safety and Intervention Plan: Cloud FinOps AI Agents

Author: Claus Albuquerque

Course: Agentic AI Program: Building Autonomous Systems for Real-World Applications

Date: August 30, 2026

1. Agent Purpose and Safety Risks

The Cloud FinOps system analyzes FOCUS 1.0 billing data to recommend rightsizing, orphaned-resource cleanup, and reservations. A FinOps Specialist proposes savings; an SRE Specialist independently checks telemetry, workload baselines, and dependencies.

Risks are asymmetric: savings are gradual, but unsafe changes can cause immediate downtime. They include resource starvation from average-based rightsizing, removal of hidden dependencies such as standbys or quorum nodes, invalid SKUs or cost calculations, prompt injection in cloud metadata, and post-change degradation under peak load.

2. Guardrails

All tags, resource names, and billing descriptions are untrusted: they are schema-validated and delimited before prompts. The FinOps agent is read-only and can only propose actions. The SRE agent is a mandatory validation gate with telemetry and dependency access; mutation tools remain outside agent reasoning and require approval.

Recommendations must verify SKUs, capacity, and pricing against official provider catalogs. A structured output schema requires a risk assessment, cost math, telemetry timestamps, and source provenance. Missing, inconsistent, or unverified evidence rejects the proposal.

3. Evaluation Metrics and Methodology

Before release, a versioned golden dataset of 50+ scenarios—including spiky workloads, warm standbys, seasonal demand, sparse telemetry, and invalid SKUs—tests cost math and SRE verdicts. Automated rubric-based evaluation measures groundedness, context adherence, and safety reasoning.

We track exact agreement with authoritative SKU, pricing, and dependency sources (target: 100%); correct escalation or veto of risky proposals; confidence calibration; clean fallback to "Insufficient Telemetry"; and end-to-end latency and token use.

4. Human Intervention & Post-Execution Safety

The system implements a structured Human-in-the-Loop (HITL) framework to balance safety with operational efficiency:

- **Tiered Autonomy (Preventing Approval Fatigue):**
 - *Tier 1 (Low Risk / Non-Production):* Dev/sandbox environments with estimated impact under \$50/month allow batched or asynchronous review to prevent engineer alert fatigue.
 - *Tier 2 (High Risk / Production):* Any action targeting `env: production`, shared clusters, stateful databases, or high-spend infrastructure mandates explicit, individualized human review and sign-off.
- **Calibrated Uncertainty Thresholds:**

- Rather than relying on subjective LLM self-confidence, the system computes a deterministic confidence score:
 - **Confidence score:** $(w1 \times \text{telemetry completeness}) + (w2 \times \text{headroom margin}) + (w3 \times \text{RAG similarity})$
 - If calculated confidence falls below **0.85**, or if critical telemetry (such as memory usage or IOPS) is missing, autonomous progression is blocked, and the recommendation is escalated with an "Ambiguity Warning".
 - **Post-Execution Canary Monitoring & Automated Rollback:**
 - Following approved execution via MCP connectors, the system initiates a **60-minute canary observation window**.
 - If CPU/Memory utilization exceeds 90% or application error rate alerts fire within this window, the orchestrator triggers an immediate high-priority alert and provides a **one-click (or automated) rollback action** to revert the resource to its previous SKU baseline.
-

5. Integrated Strategy, Trade-offs, and Deployment

The controls form a closed loop: sanitize inputs, separate cost analysis from operational validation, measure safety and accuracy, route material risk to a human, and monitor approved changes. The system fails closed when data is missing, APIs fail, or confidence is low.

Guardrails prevent unsafe proposals from progressing; evaluation verifies that those controls work across representative cases; and human review resolves situations where automated evidence is inadequate.

Canary monitoring and rollback extend this safety strategy beyond approval, so a change remains observable and reversible in operation.

Tiered autonomy balances reliability and efficiency: blanket review creates approval fatigue, while unrestricted autonomy is unacceptable in production. Independent FinOps and SRE reviews add latency and token cost—typically 3–5 seconds per request—but reduce single-agent error risk. Catalog constraints and deterministic confidence scores limit model freedom, yet improve repeatability, auditability, and policy compliance.

For real-world deployment, every recommendation retains links to the relevant FOCUS billing lines, metric windows, and SRE validation trace. This provenance, together with fail-safe defaults and reliable rollback, gives operators evidence to verify recommendations and adopt the system as a dependable decision-support tool rather than an autonomous black box.